INFRA SHIELD

Audit de serveur

vps-590f8cc9

Numéro du rapport	`5c0ffee0-1111-4e8a-9f10-2c6d8e4b1a77`
Organisation	**Alpha Tech**
Serveur	**vps-590f8cc9 (production)**
Dernier audit	**3 nov. 2026**
Généré par	**Alice Martin <alice@alpha-tech.test>**

À durcir — Score 38/100 : plusieurs points critiques exposent le serveur.

38
Score de sécurité / 100

2
Chaînes d'attaque

Synthèse pour la direction

Ce qu'il faut retenir, en langage métier.

- La posture de sécurité de le serveur vps-590f8cc9 est insuffisante : 1 risque(s) critique(s) peuvent être exploités sans action de votre part.
- 2 chaîne(s) d'attaque relient plusieurs faiblesses jusqu'à une prise de contrôle : « Brute force SSH -> root » et d'autres.
- Risque critique — prise de contrôle complète du serveur et de toutes les données qu'il héberge (Conteneur « cgt-cadvisor » en mode privilégié).
- Risque élevé — le compte root est directement exposé aux attaques (Connexion root SSH autorisée).
- Risque élevé — un mot de passe deviné par brute force ouvre le serveur (Authentification SSH par mot de passe active).
- 6 action(s) rapide(s), à effort faible, font passer le score de sécurité de 38 à 52/100.
- Première action recommandée : supprimer le mode privilégié (capacités et périphériques ciblés à la place).
- 2 contrôle(s) de sécurité en place reconnu(s).

Analyse de l'auditeur

Lecture d'ensemble des constats, de leurs liens et de leurs conséquences.

ÉTAT DE LA SÉCURITÉ

L'audit d'infrastructure du serveur vps-590f8cc9 révèle un niveau de sécurité insuffisant matérialisé par un score de 38 sur 100. La posture globale présente un risque critique lié au conteneur cgt-cadvisor exécuté en mode privilégié, combiné à deux risques élevés sur la configuration SSH. Deux chaînes d'attaque ont été identifiées, permettant d'aboutir à une prise de contrôle totale du serveur, notamment via une attaque de type brute force SSH ou l'exposition de la console cgt-prom. Si les domaines du chiffrement et de la maintenance affichent un score de 100 sur 100, les conteneurs et les accès restent vulnérables avec des scores de 60 et 63 sur 100. Plusieurs référentiels comme l'ANSSI pour GNU/Linux et Docker ou le CIS Benchmark SSH apparaissent non conformes.

CONSÉQUENCES POUR L'ORGANISATION

L'exploitation des chaînes d'attaque exposerait l'organisation à une prise de contrôle complète du serveur vps-590f8cc9 et à l'accès à l'ensemble des données hébergées. L'absence de sauvegarde chiffrée et externalisée de la base nuit à la préparation de l'organisation face aux risques de rupture d'activité. Ces vulnérabilités provoquent une non-conformité aux exigences ISO/IEC 27001:2022 relatives au contrôle d'accès et aux sauvegardes.

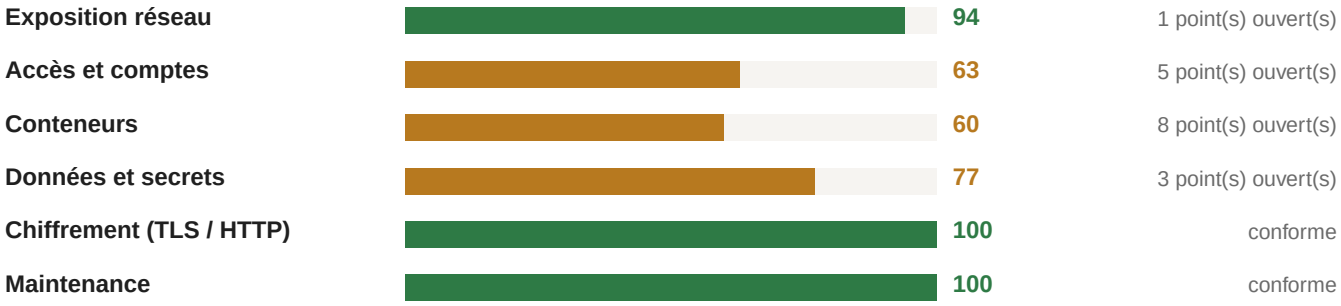
AVIS ET PRIORITÉS

L'auditeur recommande un durcissement urgent du serveur et préconise de traiter sous 24 heures la suppression du mode privilégié du conteneur cgt-cadvisor ainsi que la fermeture de la connexion SSH directe en root. Il convient d'associer immédiatement la désactivation des mots de passe SSH, la réparation du middleware d'authentification de cgt-prom et l'installation de Fail2ban ou CrowdSec. Les mesures complémentaires prévues sous 7 à 30 jours, telles que la sauvegarde chiffrée externalisée et la gestion des secrets Docker, devront par la suite être exécutées selon le plan établi.

Analyse rédigée par une IA (Gemini 3.5 Flash) à partir des seuls constats de ce rapport, sans accès au code ni aux secrets. En cas d'écart, les constats détaillés et le plan de remédiation font foi.

Niveau de maîtrise par domaine

100 = aucun point ouvert ; chaque point retire des points selon sa gravité.



Plan de remédiation priorisé

Classé par urgence puis par gain. Le gain est l'évolution du score de sécurité si l'action est faite seule.

PRIORITÉ	ACTION	EFFORT	GAIN	SÉVÉRITÉ
Immédiat (24 h)	Supprimer le mode privilégié (capacités et périphériques ciblés à la place) Concerne : cgt-cadvisor Casse la chaîne : Console « cgt-prom » exposée -> « cgt-cadvisor » -> serveur	moyen	+7 pts	critique
Immédiat (24 h)	Interdire la connexion SSH de root (PermitRootLogin no) Casse la chaîne : Brute force SSH -> root	faible	+3 pts	élevée
Immédiat (24 h)	Désactiver l'authentification SSH par mot de passe (clés uniquement) Casse la chaîne : Brute force SSH -> root	faible	+3 pts	élevée
Immédiat (24 h)	Réparer le middleware d'authentification (fichier d'utilisateurs manquant) Concerne : cgt-prom Casse la chaîne : Console « cgt-prom » exposée -> « cgt-cadvisor » -> serveur	faible	+3 pts	élevée
Immédiat (24 h)	Installer Fail2ban ou CrowdSec sur SSH Casse la chaîne : Brute force SSH -> root	faible	+1 pts	moyenne
Sous 7 jours	Planifier une sauvegarde chiffrée et externalisée de la base	moyen	+3 pts	élevée
Sous 30 jours	Passer les secrets en fichiers (Docker secrets, variantes _FILE) au lieu de variables d'environnement Concerne : cgt-prom, cgt-postgres	moyen	+2 pts	moyenne (2)

PRIORITÉ	ACTION	EFFORT	GAIN	SÉVÉRITÉ
Sous 30 jours	Publier les ports Docker sur 127.0.0.1 derrière le reverse proxy Concerne : 9090	faible	+1 pts	moyenne
Sous 30 jours	Faire tourner les services sous un utilisateur non root Concerne : cgt-prom, cgt-proxy	moyen	+1 pts	moyenne (2)
Sous 30 jours	Durcir /etc/docker/daemon.json (limite des journaux, live-restore, no-new-privileges)	faible	+1 pts	moyenne
Prochain cycle	Fixer des limites mémoire et de processus aux conteneurs Concerne : cgt-prom, cgt-proxy, cgt-cadvisor, cgt-postgres	faible	+1 pts	faible (4)
Prochain cycle	Limiter MaxAuthTries à 3	faible	—	faible

Correspondance avec les référentiels

Exigences concernées par au moins un constat ouvert ; les exigences sans écart ne sont pas listées.

RÉFÉRENTIEL	EXIGENCE	CONSTATS	STATUT
ANSSI	Configuration d'un système GNU/Linux (recommandations)	1	Non conforme
ANSSI	Déploiement de conteneurs Docker (recommandations)	5	Non conforme
CIS Benchmark Linux	Configuration du serveur SSH	3	Non conforme
CIS Docker Benchmark	§2 Configuration du démon Docker	1	Partiellement conforme
CIS Docker Benchmark	§4 Images et fichiers de build	2	Partiellement conforme
CIS Docker Benchmark	§5 Exécution des conteneurs	6	Non conforme
ISO/IEC 27001:2022	A.5.15 Contrôle d'accès	1	Non conforme
ISO/IEC 27001:2022	A.5.17 Informations d'authentification	2	Partiellement conforme
ISO/IEC 27001:2022	A.5.30 Préparation des TIC à la continuité	1	Non conforme
ISO/IEC 27001:2022	A.8.13 Sauvegarde des informations	1	Non conforme
ISO/IEC 27001:2022	A.8.2 Droits d'accès privilégiés	4	Non conforme
ISO/IEC 27001:2022	A.8.20 Sécurité des réseaux	1	Partiellement conforme
ISO/IEC 27001:2022	A.8.5 Authentification sécurisée	3	Non conforme
ISO/IEC 27001:2022	A.8.9 Gestion de la configuration	5	Partiellement conforme
OWASP Top 10 2021	A01 Contrôle d'accès défaillant	1	Non conforme
OWASP Top 10 2021	A05 Mauvaise configuration de sécurité	3	Partiellement conforme
OWASP Top 10 2021	A07 Identification et authentification	3	Non conforme

PARTIE 2

Constats détaillés

Le détail technique de chaque point.

...

Signature électronique

Document signé électroniquement par CodeGate

SIGNATAIRE
CN=CodeGate Audit Report Signing, O=CodeGate, OU=Security Evidence, C=FR

DATE DE SIGNATURE
3 nov. 2026, 22:05

MÉTHODE
Signature PDF PKCS#7 détachée · SHA-256 · RSA

EMPREINTE DU CERTIFICAT
`A6:BC:26:4F:F4:60:6C:D4:33:B4:20:2D:EB:8F:58:DA:B7:7C:0F:EE:32:08:C1:E7:AD:D1:2E:66:A9:0D:79:A3`

NUMÉRO DU RAPPORT
`5c0ffee0-1111-4e8a-9f10-2c6d8e4b1a77`

Scannez pour vérifier

La signature couvre l'intégralité du fichier : toute modification, même d'un caractère, la rend invalide dans un lecteur PDF (Adobe Acrobat, Foxit…). L'empreinte SHA-256 du fichier émis est enregistrée dans le registre CodeGate : déposez votre copie sur la page de vérification pour confirmer qu'elle est authentique et intacte.

https://codegate.example/verify/5c0ffee0